

Introduction to Cyber Security

Dr Ramokapane

What is cyber security?

Cyber security: refers to the protection of information systems (hardware, software and associated infrastructure), the data on them, and the services they provide, from unauthorised access, harm or misuse. This includes harm caused intentionally by the operator of the system, or accidentally, as a result of failing to follow security procedures.

UK National Cyber Security Centre

Information security: preservation of confidentiality, integrity and availability of information. In addition, other properties, such as authenticity, accountability, non-repudiation, and reliability can also be involved.

ISO 27000 definition

Computer security

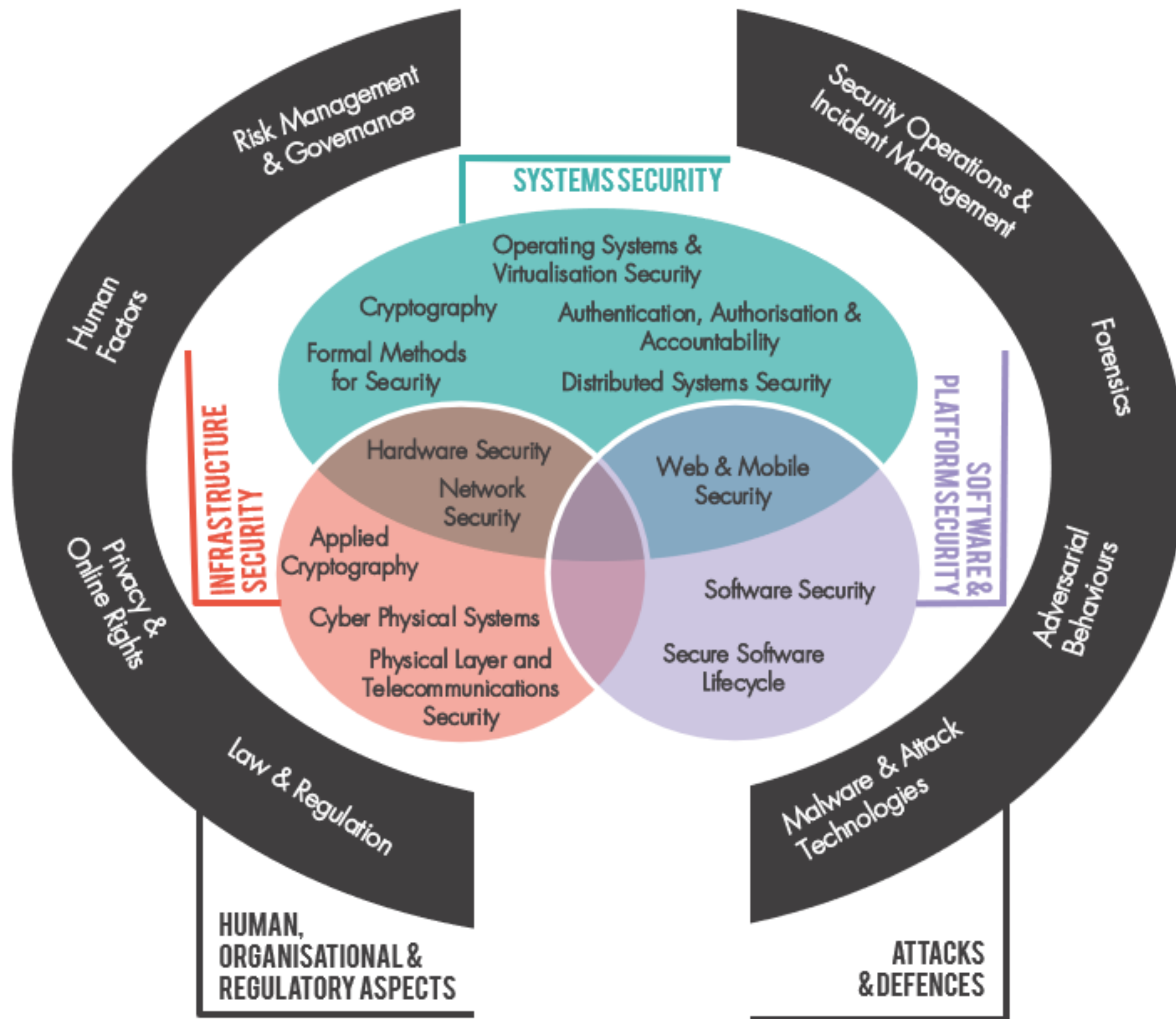
Network security

Information Assurance

Systems Security

Security Engineering

...



Saltzer and Schroeder

Principles

J. H. Saltzer and M. D. Schroeder, “The protection of information in computer systems,” Proceedings of the IEEE, vol. 63, no. 9, pp. 1278–1308, Sep. 1975.

Economy of Mechanism

Design of security controls should remain as simple as possible — to ensure high assurance

Trusted Computing Base (TCB)

Must remain small!

Fail-safe Defaults

Define and enable operations that can positively be identified as being in accordance with a security policy, and reject all others

Inclusion of known good behaviour

Exclusion based on detection of malicious behaviour is problematic

Signature-based anti-virus, IDS

Complete Mediation

Check all operations on objects for compliance with security policy

Identity or *allowed* capability of the subject

Open Design

No security by obscurity!

Separation of Privilege

Multiple subjects authorising operations on an object

Higher assurance of integrity

Reduced availability

Tragedy of the security commons!

Least Privilege

Read vs. write/delete

Avoids problems with corrupt or incorrect subjects (e.g., software)

Key principle in security architectures to minimise the impact of partial compromises

Least Common Mechanism

Minimise shared resources and system features between different parties

Multi-user systems (shared CPU, memory, disk storage)

Extreme: air-gap

Psychological Acceptability

Usable security

Saltzer and Schroeder Principles



Kerckhoff's principles on cryptographic systems

NIST Principles

Architecture Strategies

Reference Monitor

Defence in Depth

Isolation

Clear Abstraction

Modularity and Layering

Secure Evolvability

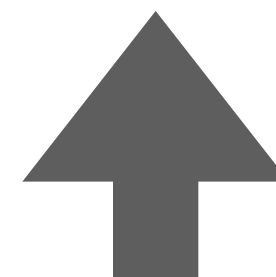
Hierarchical Trust Model

Trusted Communication Channels

Inverse Modification Threshold

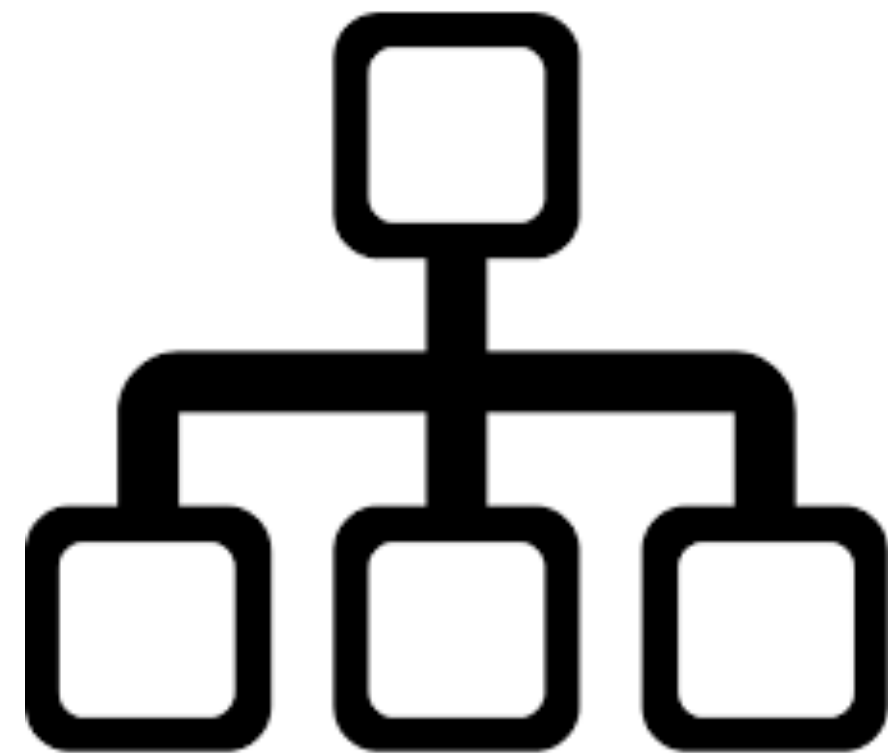
Secure Distributed Composition

■ ■ ■



Saltzer and Schroeder

Broken Abstractions



Qualities

Confidentiality

Integrity

Availability

Non-repudiation

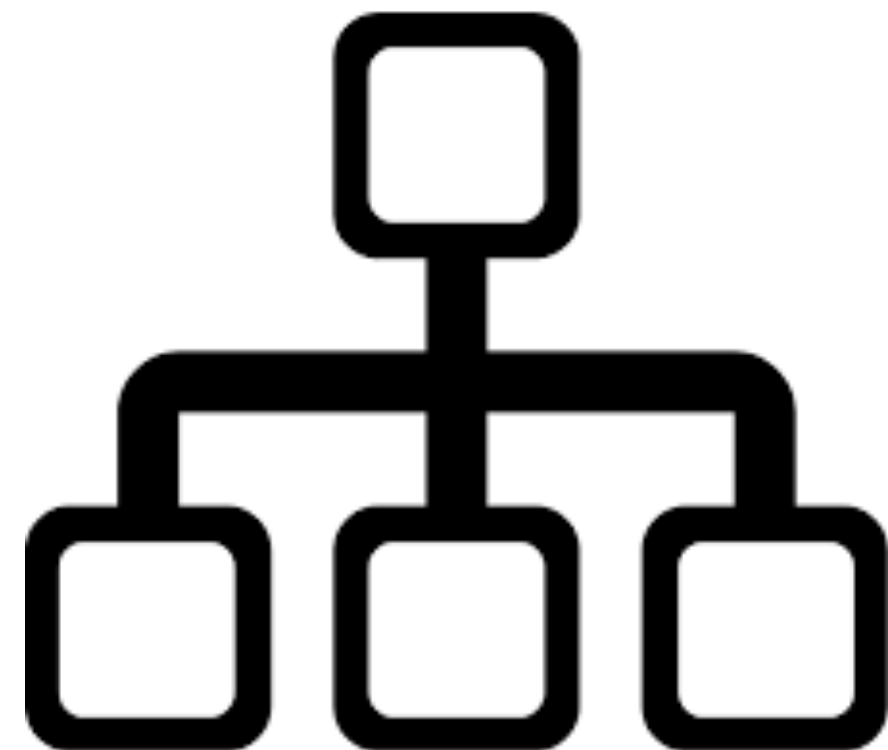
Auditability

Safety

Resilience

...

Boundaries



Qualities

Confidentiality

Integrity

Availability

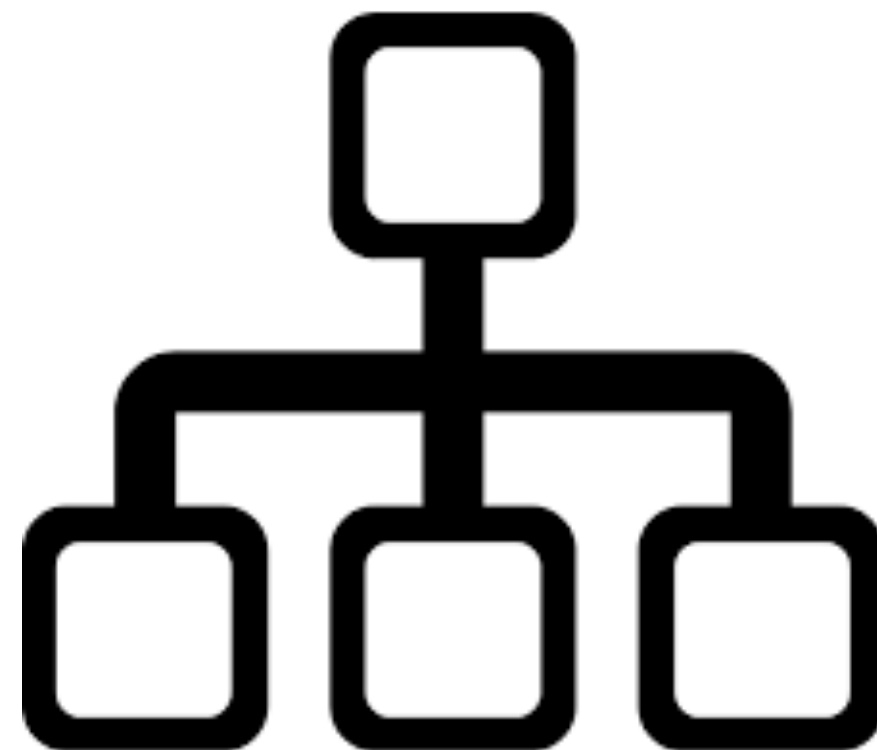
Non-repudiation

Auditability

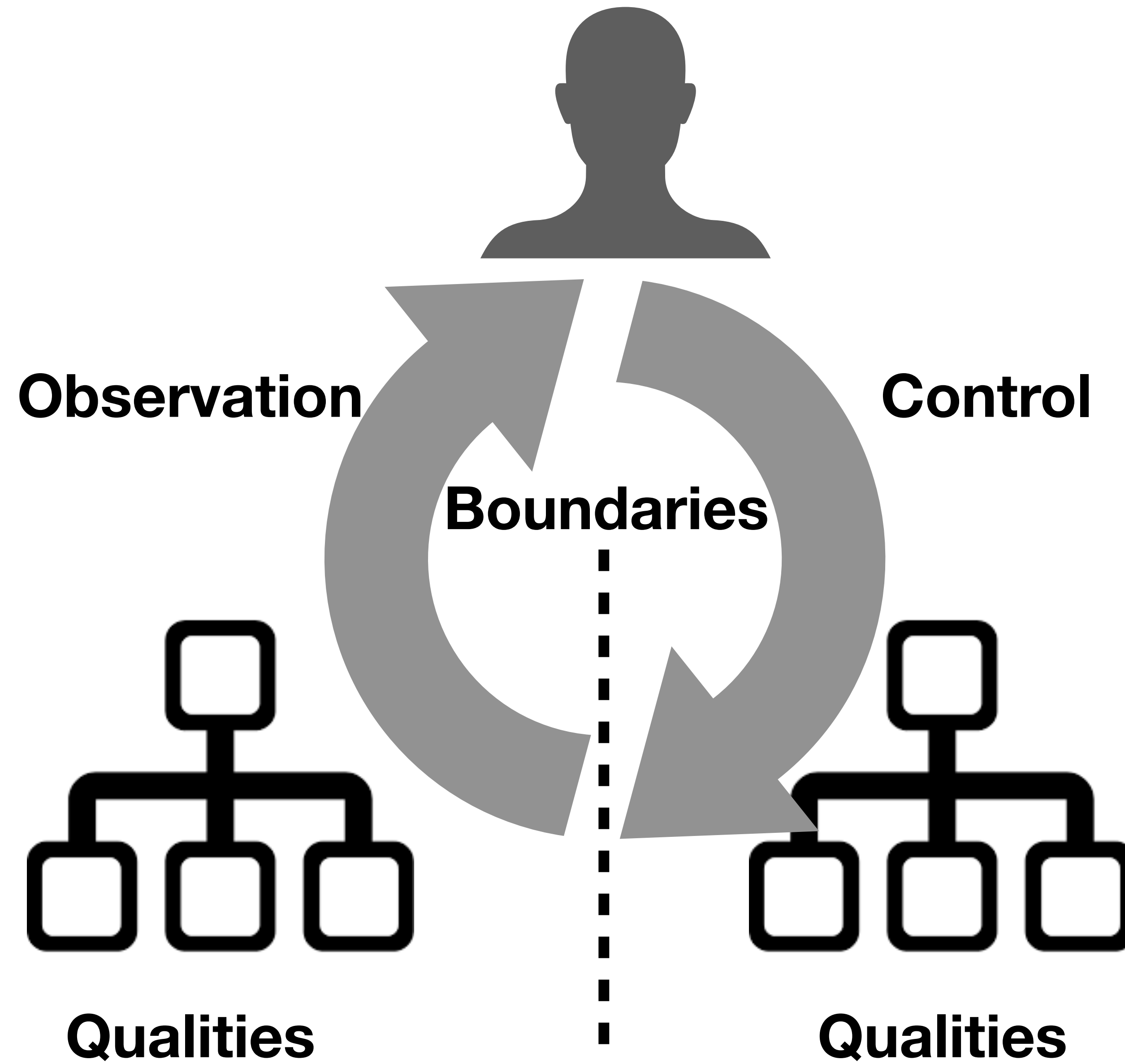
Safety

Resilience

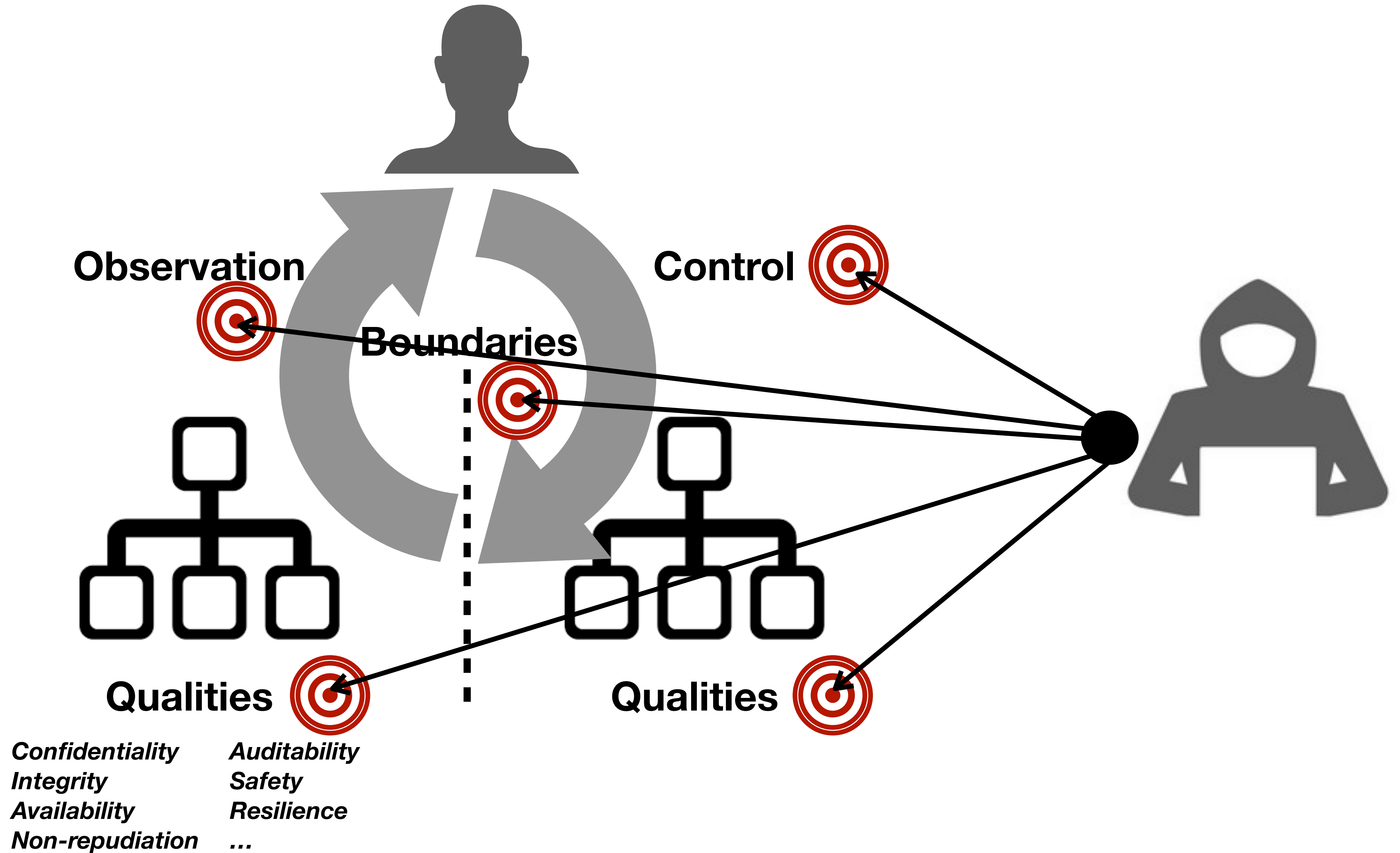
...



Qualities



<i>Confidentiality</i>	<i>Auditability</i>
<i>Integrity</i>	<i>Safety</i>
<i>Availability</i>	<i>Resilience</i>
<i>Non-repudiation</i>	<i>...</i>



Security Economics

Work factor Principle (Saltzer and Schroeder)

Further Reading

Introduction to the Cyber Security Body of Knowledge: https://www.cybok.org/media/downloads/Introduction_v1.1.0.pdf

J. H. Saltzer and M. D. Schroeder, “The protection of information in computer systems,” Proceedings of the IEEE, vol. 63, no. 9, pp. 1278–1308, 1975.
Available: <https://doi.org/10.1109/PROC.1975.9939>

R. Ross, M. McEvilly, and J. C. Oren, “Systems security engineering: Considerations for a multidisciplinary approach in the engineering of trustworthy secure systems,” NIST, Tech. Rep. NIST.SP.800-160 Volume 1, Nov. 2016. Available: <https://doi.org/10.6028/NIST.SP.800-160v1>